REDEEMER'S UNIVERSITY
...running with the vision

GEORGE-OMOSUN GODSWILL

RUN/CYB/24/17318

CYB 401: VULNERABILITIES ASSESSMENT

CVE-2026-33626: LMDeploy Server-Side Request Forgery Vulnerability

1. Vulnerability Details

Severity: High — CVSS 3.1 score: 7.5/10
Affected software: LMDeploy (open-source toolkit for serving large language models)
Vulnerability type: Server-Side Request Forgery (SSRF), CWE-918
Affected versions: LMDeploy versions earlier than 0.12.3
Patched version: 0.12.3
NVD record: https://nvd.nist.gov/vuln/detail/CVE-2026-33626

LMDeploy is a toolkit for compressing, deploying, and serving large language models. **CVE-2026-33626** affects the vision-language functionality of LMDeploy. The vulnerable *load_image()* function in 'lmdeploy/vl/utils.py' retrieves images from URLs without adequately validating whether the destination is an internal, private, or otherwise restricted address.

An attacker can send requests to an exposed, vulnerable LMDeploy service and abuse its image-loading functionality to make the server send requests to destinations the attacker cannot access directly. These may include internal services, cloud metadata endpoints, and administrative interfaces. Potential consequences include exposure of sensitive information, discovery of internal services, and possible access to cloud credentials.

Severity Score Explained
CVSS 3.1 vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

- **AV:N — Network:** The attack can be initiated over a network.
- **AC:L — Low complexity:** No unusual attack conditions are required.
- **PR:N — None:** The attacker does not need an account.
- **UI:N — None:** No other user's action is required.
- **S:U — Unchanged scope:** The scored impact is within the vulnerable system's security authority.
- **C:H — High confidentiality impact:** Sensitive information may be exposed.
- **I:N/A:N –- None:** The published base score does not assign direct integrity or availability impact.

This score reflects the vulnerability's assessed technical severity, not the likelihood that every deployment will be compromised.

2. CVE-2026-33626 in Relation to the Cyber Kill Chain

Kill Chain Stage	Possible Attack Activity	Cybersecurity Experts' Response
1. Reconnaissance	An attacker identifies publicly accessible LMDeploy servers and investigates their versions, API endpoints, and vision-language functionality.	Maintain an inventory of AI services, scan for exposed endpoints, and identify vulnerable software versions.
2. Weaponization	The attacker prepares requests containing image URLs that point to internal or restricted resources.	Validate URLs, resolve and verify destination IP addresses, block private and link-local ranges, and test security controls.
3. Delivery	The attacker submits a crafted request to the vulnerable /v1/chat/completions API using the image_url field.	Require appropriate API authentication, validate request parameters, and restrict access to exposed inference endpoints.
4. Exploitation	The vulnerable image loader makes server-side requests to unintended destinations, potentially reaching cloud metadata or internal services.	Upgrade LMDeploy to version 0.12.3 or later, restrict outbound traffic, and monitor requests to internal IP addresses.
5. Installation	SSRF alone does not install malware. In a broader intrusion, an attacker may attempt additional actions to establish persistence if another weakness permits it.	Check for unauthorized files, processes, services, and configuration changes. Do not assume persistence occurred without evidence.
6. Command and Control	The attacker may use external callbacks to confirm that server-side requests are possible. Such callbacks alone do not establish a command-and-control channel.	Monitor unexpected DNS and HTTP traffic, restrict outbound connections, and investigate unusual destinations.
7. Actions on Objectives	The attacker may attempt to obtain cloud credentials, discover internal services, access sensitive information, or disrupt AI infrastructure through additional weaknesses.	Investigate possible credential exposure, rotate affected credentials, audit internal services, and contain any confirmed compromise.

3. Cybersecurity Experts' Response and Patches from NVD

The NVD record identifies the vulnerability and provides the authoritative record for tracking its remediation. The associated vendor advisory and patch provide implementation details.

1. Apply the official patch. Upgrade LMDeploy to v0.12.3 or later. The associated fix adds URL safety checks in the image-loading path.
Release: https://github.com/InternLM/lmdeploy/releases/tag/v0.12.3

2. Validate and restrict URLs. Allow only required URL schemes, resolve hostnames, block loopback/private/link-local destinations, and account for DNS rebinding and redirects. Enforce URL checks throughout the request process.

3. Restrict network access. Apply outbound firewall or cloud network rules so inference servers can reach only the services they need. Require authentication on internal databases and administrative interfaces.

4. Protect cloud credentials. Enforce cloud-provider metadata-service protections, such as AWS IMDSv2 where applicable. Rotate credentials if a vulnerable publicly accessible instance may have exposed them.

5. Investigate and verify. Review application, DNS, firewall, and cloud audit logs for unexpected internal requests. Retest the patched version and confirm that attempts to access restricted destinations are blocked.

The patch and mitigation recommendations are consistent with the GitHub security advisory and Sysdig incident analysis. Sysdig also recommended treating exposed deployments of vulnerable versions as potentially compromised and rotating attached cloud credentials where exposure is plausible.